

1: Title Slide

TraceMail AI

Autonomous Forensic Email Threat Investigation & Threat Intelligence Correlation Platform

- **Team:** TraceMail AI Engineering Team
- **Problem Statement ID:** SIH2024 - Cybersecurity Track
- **Category:** Software / Cloud Architecture / Cyber Defense
- **Live System:** tracemail-ai-84ho.vercel.app
- **Tagline:** "Transforming 45-Minute Email Forensic Triage into 30-Second Explainable Intelligence"

2: Problem Statement

The Critical Bottleneck in Email Incident Response

- **The Threat:** Email-based attacks (phishing, spoofing, Business Email Compromise) account for over **90% of organizational cyber breaches**.
 - **The Operational Gap:** When a malicious email bypasses perimeter filters, SOC Tier-1/Tier-2 analysts face an exhausting, manual investigation:
 - Manually inspecting RFC 5322 Received: headers to locate the true origin server.
 - Cross-referencing 5 to 10 disjoint web portals (VirusTotal, AbuseIPDB, URLScan, WHOIS, DNS TXT records).
 - Falling prey to attacker-forged Received: headers that masquerade as innocent relays.
 - **The Business Impact:** Manual triage takes **20–45 minutes per email**. High incident volume leads to severe alert fatigue, missed zero-day attacks, and unsealed, legally inadmissible evidence chains.
-

3: Proposed Solution

TraceMail AI: End-to-End Autonomous Email Forensics

TraceMail AI provides an automated, explainable, and legally defensible email threat investigation platform:

- **Dual-Stream Ingestion:** Analyze raw .eml uploads or stream live mailboxes via Google OAuth2 (gmail.readonly).
- **Spoofing-Resistant Parsing:** Patented Trusted-MTA boundary extraction identifies genuine attacker IPs despite pre-injected forged headers.
- **Canonical Multi-Provider Correlation:** Live parallel enrichment across 7 industry-standard intelligence feeds with strict timeouts and zero crash cascades.
- **Explainable AI (XAI) Scoring:** Deterministic mathematical weights (0–100) paired with Groq Cloud LLaMA-3 executive incident narratives.
- **Cryptographic Evidence Locker:** Automated SHA-256 evidence hashing establishing an unalterable digital chain of custody with real-time tamper detection.

4: Existing Solutions vs. Limitations

Why Legacy Tools Fall Short in Forensic Triage

Solution Category	Key Examples	How They Work	Critical Limitations
Secure Email Gateways (SEGs)	Proofpoint, Mimecast, Defender	Inline binary filtering (deliver, drop, quarantine)	Opaque scores; no interactive forensic drill-down when an attack slips through to the user.
SIEM & SOAR Platforms	Splunk, Sentinel, Cortex XSOAR	Ingest high-level security logs and trigger playbooks	High licensing cost; log-centric rather than message-centric; requires complex custom playbook setup.
Manual Threat Portals	VirusTotal GUI, AbuseIPDB web	Individual manual searches across browser tabs	Highly fragmented; context switching; prone to human error; lacks automated evidence sealing.
TraceMail AI	<i>Production Deployed</i>	Unified deep-dive forensic engine + live multi-intel	Automated, transparent, spoofing-resistant, SME-accessible.

5: Unique Value Proposition (UVP)

Four Genuinely Differentiated Capabilities

1. Trusted-MTA Spoofing Resistance:

- Instead of naively reading bottom-most Received: headers (which attackers forge), TraceMail AI identifies the earliest verified receiving MX gateway to extract the unforgeable TCP socket peer IP.

2. Normalized Multi-Source Intel Gateway:

- Synchronous or parallel querying across VirusTotal v3, AbuseIPDB v2, IPinfo, URLScan.io, Google Safe Browsing v4, ICANN RDAP/WHOIS, and live DNSSEC/DNS resolvers into a single deterministic schema.

3. Mathematically Grounded Explainable AI:

- Generative summaries from Groq Cloud LLaMA-3 are strictly constrained by calculated forensic weights across Authentication (30%), Domain Age (20%), Intel Feeds (30%), and Content Heuristics (20%) — **zero AI hallucinations**.

4. Legally Defensible Evidence Locker:

- Instant SHA-256 cryptographic sealing upon ingestion with continuous tamper-audit verification for forensic and courtroom compliance.

6: Technical Architecture

Decoupled Cloud-Native Micro-Architecture

- **Presentation Layer (Vercel):** Next.js 15, React 19, TypeScript, Tailwind CSS, Lucide icons, responsive interactive UI.
 - **Application Layer (Railway):** FastAPI (Python 3.12), Uvicorn ASGI server, Pydantic v2 schemas, SQLAlchemy ORM.
 - **Persistence Layer (PostgreSQL 16):** 16 normalized relational tables with strict foreign key constraints and row-level locking.
 - **Intelligence Layer:** 7 external threat APIs executing with timeout-bounded async workers (`asyncio.gather`).
 - **Mailbox Streaming:** Google OAuth 2.0 protocol restricted to read-only mailbox monitoring.
 - **Geospatial & OSINT Layer:** Google Maps Platform integration (Directions polylines, Geocoding, Places infrastructure OSINT, and heatmaps).
-

7: Real Tech Stack (No Placeholder Dependencies)

Proven, Open-Source & Enterprise-Grade Technologies

- **Frontend:**
 - Next.js 15 (App Router, Turbopack)
 - TypeScript 5, Tailwind CSS
 - Lucide React Icons
 - Deployed on **Vercel Edge Network**
- **Backend:**
 - Python 3.12, FastAPI, Uvicorn
 - SQLAlchemy 2.0, Alembic
 - Pydantic v2 (strict validation)
 - Deployed on **Railway Cloud Containers**
- **Database:**
 - PostgreSQL 16 (Hosted on Railway)
 - 16 Tables, Indexed Foreign Keys, Row-Level Locks
- **Threat Intelligence & AI:**
 - VirusTotal v3, AbuseIPDB v2, IPinfo, URLScan.io, Google Safe Browsing v4
 - ICANN RDAP / WHOIS, dnspython (SPF/DKIM/DMARC)
 - Groq Cloud LLaMA-3 (High-Speed LLM Inference)
- **Testing & Quality Assurance:**
 - pytest, pytest-asyncio (83 passing backend tests)
 - TypeScript static analysis & production build checks

8: Investigation Workflow

From Raw Message to Forensic Evidence in 5 Stages

```
[ Ingestion ] —————> Raw .EML upload OR Live Gmail OAuth2 API Fetch
                        |
[ Stage 1: Deconstruct ] —> RFC 5322 Parsing, Multipart MIME, Display-Name Spoofing Check
                        |
[ Stage 2: MTA Anchor ] —> Identify Earliest Trusted MX Hop —> Extract True Public IP
                        |
[ Stage 3: Live Intel ] —> Parallel Queries: VirusTotal + AbuseIPDB + URLScan + DNS + RDAP
                        |
[ Stage 4: Scoring & XAI ] —> Deterministic Metric Weighting (0-100) + Groq LLaMA-3 Narrative
                        |
[ Stage 5: Seal Evidence ] —> Compute SHA-256 Hash —> Commit to Evidence Locker with Custody Log
```

9: Feasibility & Viability

Tested Reliability, Fault Tolerance & Cost Economics

- **Proven Deployment:** Both frontend (Vercel) and backend (Railway) are live, containerized, and publicly accessible today.
- **Graceful Degradation:** All external threat intelligence clients execute within strict 5–8 second timeouts. If an external API is offline or rate-limited, the pipeline continues without user-facing crashes.
- **Row-Level Concurrency:** Built-in PostgreSQL `with_for_update()` row-level locks prevent race conditions during simultaneous scans of identical messages.
- **Cost Efficiency:**
 - Built on open-source frameworks (FastAPI, Next.js, PostgreSQL).
 - Utilizes standard developer-tier and freemium threat intel APIs.
 - Highly affordable for educational institutions, government departments, and SMEs.

10: Impact & Measurable Benefits

Elevating SOC Defense Capabilities

- **Time Compression:** Reduces per-incident forensic triage time from **~30 minutes to under 30 seconds** (a ~98% time reduction).
 - **Cognitive Relief:** Eliminates manual multi-tab browser juggling; presents single-pane-of-glass forensic visualization.
 - **Spoofing Immunity:** Eliminates misattribution caused by forged Received: headers.
 - **Forensic Defensibility:** Guarantees cryptographic chain of custody (SHA-256) for regulatory compliance and legal proceedings.
 - **Accessibility:** Bridges the cybersecurity tooling divide for resource-constrained organizations unable to afford \$50,000+ annual enterprise SIEM/SOAR contracts.
-

11: Validation & Security Hardening

Verified Through Rigorous Production Audits

- **83/83 Automated Tests Passing:**
 - 100% pass rate across unit, integration, and security test suites.
 - Specific tests verify Trusted-MTA spoofing resilience (`test_inbox_investigate.py`), concurrency, and tamper detection.
- **Verified Strict Tenant Isolation:**
 - Tested with real stranger accounts in production.
 - Zero cross-tenant data leakage: non-owners receive 403 Forbidden on both scan and results endpoints.
 - 0 administrative over-grants: all users operate with least-privilege analyst roles.
- **Production Mode Enforced:**
 - `ENVIRONMENT=production`, `USE MOCK THREAT INTEL=false`, `ENABLE_DEMO_SEED=false`.
 - Zero hardcoded mock fallback data in production.

12: Current Status & Future Roadmap

Where We Are Today & Where We Are Going

- **Current Status (Phase 1 — Complete):**

- [x] Full RFC-822 / EML forensic decomposition engine.
- [x] Trusted-MTA boundary origin extraction.
- [x] 7-provider live threat intelligence correlation.
- [x] Live Gmail OAuth2 read-only inbox scanning.
- [x] Explainable AI (Groq LLaMA-3) & SHA-256 Evidence Locker.
- [x] 16-table PostgreSQL schema & Next.js 15 UI.

- **Next Horizon (Phase 2 — In Progress / Planned):**

- [] **Q4 2026:** Distributed task queue integration (Celery + Redis) for enterprise high-throughput mail streams.
- [] **Q1 2027:** Microsoft Graph API (Office 365 / Outlook) connector alongside Gmail.
- [] **Q2 2027:** Dynamic sandbox execution for zero-day macro and executable attachments.
- [] **Q3 2027:** Standardized load and latency benchmarking (Locust / JMeter).

13: Team & Roles

TraceMail AI Engineering Team

- **Lead Architect & Full-Stack Engineer:**
 - Systems architecture, FastAPI backend development, Next.js frontend, database modeling.
 - **Cybersecurity & Threat Intelligence Specialist:**
 - RFC 5322 header parsing, Trusted-MTA algorithm design, API gateway integration.
 - **Cloud Infrastructure & Security Auditor:**
 - Railway container orchestration, Vercel deployments, tenant isolation audit, cryptographic evidence verification.
 - **Product & UI/UX Designer:**
 - Incident investigation workflow design, SOC dashboard layout, geospatial OSINT mapping interfaces.
-

14: Conclusion & Q&A

TraceMail AI: Autonomous, Explainable, Cryptographically Sealed Email Forensics

- Production Prototype Live: <https://tracemail-ai-84ho.vercel.app>
- API Status Live: <https://tracemail-ai-production.up.railway.app/health/apis>
- Repository: github.com/nleelaranga-ai/tracemail-ai

"Protecting digital communications through deep forensics, verified intelligence, and uncompromised chain of custody."

Thank You!

Questions & Technical Discussion